

Plantilla de Excel para cálculo de IGM y ROI STRIDE

Esta plantilla describe la estructura recomendada de un libro de Excel para:

- Calcular un Índice Global de Madurez STRIDE (IGM-STRIDE).
- Estimar métricas básicas de retorno de inversión (ROI) en seguridad.

1. Estructura del libro

Se recomiendan al menos las siguientes hojas:

1. Respuestas: codificación de las respuestas de la encuesta.
2. Ponderaciones: pesos por pregunta y por categoría STRIDE.
3. Cálculos_IGM: cálculos de puntuaciones parciales y global.
4. ROI: estimaciones de impacto económico y ROI.
5. Resumen_Ejecutivo: visualización simplificada para dirección.

2. Hoja “Respuestas”

Columnas sugeridas:

- ID_Pregunta (texto, p.ej. P-S-01).
- Bloque_STRIDE (S, T, R, I, D, E, GOV, MET).
- Descripción (abreviada).
- Opción_Marcada (texto).
- Puntuación (numérica).

Ejemplo de codificación:

- Nivel muy alto de madurez → 3.
- Nivel medio → 2.
- Nivel bajo → 1.
- Ausencia / desconocimiento → 0.

La celda Puntuación puede llenarse manualmente o mediante validación de datos y fórmula de búsqueda (por ejemplo, usando una tabla auxiliar con mapeo opción–puntuación).

3. Hoja “Ponderaciones”

Columnas sugeridas:

- ID_Pregunta.
- Peso_Pregunta (0–1).
- Peso_STRIDE (0–1) por categoría, si se quiere ajustar la importancia relativa de cada letra.

Se pueden definir pesos de forma:

- Uniforme (todas las preguntas valen lo mismo).
- Diferenciada (mayor peso a controles considerados críticos según NIS2/ENS).

Ejemplo simple:

- Todas las preguntas de gobierno y métrica: peso 1,0.
- Preguntas clave por categoría STRIDE (MFA, PAM, logging, continuidad): peso 1,5.
- Resto de preguntas: peso 1,0.

4. Hoja “Cálculos_IGM”

Pasos básicos:

6.

Puntuación por pregunta ponderada

$\text{Puntuacion_Ponderada} = \text{Puntuación} * \text{Peso_Pregunta}.$

7.

Puntuación por categoría STRIDE

Para cada categoría (S, T, R, I, D, E, GOV, MET):

8. $\text{Suma_Puntos} = \text{SUMA}(\text{Puntuacion_Ponderada} \text{ donde Bloque_STRIDE} = 'S')$

9. $\text{Suma_Pesos} = \text{SUMA}(\text{Peso_Pregunta} \text{ donde Bloque_STRIDE} = 'S')$

10. $\text{Puntuacion_Normalizada_S} = \text{Suma_Puntos} / (3 * \text{Suma_Pesos})$
(suponiendo que 3 es la puntuación máxima posible por pregunta).

Puntuación por pregunta ponderada

$\text{Puntuacion_Ponderada} = \text{Puntuación} * \text{Peso_Pregunta}.$

Puntuación por categoría STRIDE

Para cada categoría (S, T, R, I, D, E, GOV, MET):

Esto produce un valor entre 0 y 1 para cada categoría.

11. Índice Global de Madurez STRIDE (IGM-STRIDE)
12. Calcular la media ponderada de las seis categorías STRIDE (S, T, R, I, D, E) más, si se desea, gobierno (GOV) y métricas (MET).
13.
Por ejemplo:
$$\text{IGM} = (S + T + R + I + D + E + \text{GOV} + \text{MET}) / 8.$$
14.
Clasificación cualitativa
Definir rangos:
15.
0,00–0,24 → “Inicial / Reactivo”.
16. 0,25–0,49 → “Básico”.
17. 0,50–0,74 → “Intermedio”.
18. 0,75–1,00 → “Avanzado”.

Por ejemplo:

$$\text{IGM} = (S + T + R + I + D + E + \text{GOV} + \text{MET}) / 8.$$

Clasificación cualitativa

Definir rangos:

0,00–0,24 → “Inicial / Reactivo”.

La hoja puede incluir fórmulas SI () para traducir el valor a texto y usar formatos condicionales (colores tipo semáforo).

5. Hoja “ROI”

El ROI en seguridad rara vez es una ciencia exacta, pero se puede aproximar:

Columnas sugeridas:

- Control (por ejemplo, “MFA en accesos críticos”).
- Coste_Anuual (euros).
- Riesgo_Inicial (valor anual esperado de pérdida relacionada, en euros).
- Riesgo_Residual (valor anual esperado tras el control).
- Beneficio_Anuual = Riesgo_Inicial - Riesgo_Residual.
- ROI = Beneficio_Anuual / Coste_Anuual.

Fuente de datos:

- Riesgo inicial y residual pueden estimarse combinando:
- Probabilidad de incidentes (por datos históricos internos o referencias sectoriales).
- Impacto económico de incidentes (costes directos, interrupciones, sanciones).

Ejemplo simplificado:

- Coste anual de MFA: 100.000 €.
- Riesgo anual esperado de incidentes de suplantación sin MFA: 500.000 €.
- Riesgo residual tras MFA: 150.000 €.
- Beneficio anual: 350.000 €.
- ROI $\approx$ 3,5 (o 350 %).

La hoja puede incluir:

- Una tabla con controles clave alineados con las preguntas de la encuesta.
- Fórmulas para comparar “escenarios sin control” vs. “con control”.
- Gráficos que muestren la contribución de cada control a la reducción de riesgo.

6. Hoja “Resumen_Ejecutivo”

Elementos recomendados:

- Tabla con puntuaciones normalizadas por categoría STRIDE (0–1) y su calificación cualitativa.
- Gráfico radar (o de barras) comparando S, T, R, I, D, E, GOV, MET.
- Valor global de IGM-STRIDE con comentario interpretativo.
- Selección de 3–5 controles con mejor ROI estimado.
- Lista de 3–5 áreas prioritarias de mejora, con referencia directa a preguntas de la encuesta.

La idea es que la dirección pueda ver, en una sola pantalla, tres cosas:

19. Dónde está la organización (IGM-STRIDE y perfil por categoría).
20. Qué controles aportan más “impacto por euro” invertido.
21. Dónde están las brechas que pueden comprometer el cumplimiento normativo o la continuidad de negocio.

7. Adaptación y refinamiento

La plantilla está pensada como punto de partida. Se recomienda:

- Ajustar ponderaciones según sector (sanidad, energía, finanzas, etc.).
- Incorporar datos históricos internos de incidentes para calibrar estimaciones de riesgo.
- Revisar anualmente las funciones de riesgo y ROI para reflejar cambios en el entorno de amenazas y la normativa.